

Estándares de Ciberseguridad / Asignacion lab 7 (core)

ISO 27001: Implementación de Controles de Seguridad

Paso 1: Implementación de Controles

Cinco controles esenciales de la norma ISO 27001 para proteger la información crítica de Global Data Inc.:

1. Gestión de Acceso (Control A.9)

- **Descripción:** Establece procedimientos para asegurar que solo el personal autorizado pueda acceder a la información crítica.
- **Implementación:** Utilizaría un sistema de autenticación multifactorial (MFA) para el acceso a sistemas críticos. Además, se definirían permisos de acceso específicos basados en roles, garantizando que cada empleado tenga acceso únicamente a la información necesaria para su función.

2. Políticas de Seguridad de la Información (Control A.5)

- **Descripción:** Este control requiere que la organización desarrolle y mantenga políticas de seguridad de la información claras y bien documentadas.
- **Implementación:** Desarrollaría políticas que cubran temas como la gestión de contraseñas, uso de dispositivos externos, acceso remoto y uso aceptable de los recursos de la empresa. Estas políticas serían comunicadas a todo el personal a través de una plataforma de capacitación continua.

3. Cifrado de Datos (Control A.10)

- **Descripción:** El objetivo es proteger la confidencialidad e integridad de la información mediante cifrado en tránsito y en reposo.
- **Implementación:** Implementaría cifrado AES-256 para datos sensibles almacenados y protocolo TLS para datos en tránsito. Esto aseguraría que la información esté protegida contra accesos no autorizados, incluso si se produce una brecha en la red.

4. Evaluación y Tratamiento de Riesgos (Control A.12)

- **Descripción:** Establece la necesidad de evaluar y gestionar los riesgos de seguridad de la información.
- **Implementación:** Llevaría a cabo una evaluación inicial de riesgos para identificar y clasificar activos y amenazas. Basado en los resultados, implementaría controles adicionales y revisaría periódicamente estos riesgos para actualizar las medidas de seguridad según cambios en el entorno o en la organización.

5. Capacitación y Conciencia en Seguridad (Control A.7)

- **Descripción:** Promueve la capacitación continua para que los empleados comprendan los riesgos de seguridad y cómo proteger la información de la organización.

- **Implementación:** Se implementaría un programa de capacitación anual obligatorio sobre seguridad de la información, además de realizar campañas trimestrales de concienciación. También incluiría simulaciones de phishing para reforzar el conocimiento de los empleados.
-

Paso 2: Monitoreo de la Seguridad

Plan de Monitoreo de Controles: Para asegurar la efectividad de los controles implementados, es fundamental contar con un plan de monitoreo continuo.

1. Gestión de Acceso:

- **Monitoreo:** Realizar auditorías mensuales de acceso para identificar accesos no autorizados o patrones sospechosos.
- **Corrección:** Si se detectasen fallos, revisar y ajustar los permisos, y reforzar el control de autenticación en caso de accesos indebidos o a contratiempo

2. Políticas de Seguridad de la Información:

- **Monitoreo:** Supervisar el cumplimiento de las políticas mediante auditorías internas y revisiones de cumplimiento cada 2 meses.
- **Corrección:** En caso de violaciones de política, se tomaran medidas disciplinarias y se proporcionarán sesiones de capacitación al personal implicado.

3. Cifrado de Datos:

- **Monitoreo:** Verificar cada bimestre que el cifrado esté activado y configurado correctamente, además de comprobar que se mantenga la confidencialidad e integridad de los datos.
- **Corrección:** Actualizar los certificados de cifrado en caso de fallos, y revisar el proceso si se detectan vulnerabilidades.

4. Evaluación y Tratamiento de Riesgos:

- **Monitoreo:** Hacer revisiones de riesgos cada seis meses para detectar posibles cambios y actualizar las medidas de control.
- **Corrección:** Implementar nuevos controles si aparecen nuevos riesgos y ajustar las políticas y procedimientos de tratamiento de riesgos.

5. Capacitación y Conciencia en Seguridad:

- **Monitoreo:** Evaluar la efectividad de la capacitación mediante pruebas de seguridad y simulaciones trimestrales (ej., pruebas de phishing, chequeos de malware, spyware).
 - **Corrección:** Si se observa un bajo rendimiento, reforzar la capacitación y mejorar el contenido de los entrenamientos.
-

Paso 3: Documentación de Controles

1. Documentación de Implementación de Controles:

- **Gestión de Acceso:** Analizar y documentar los procedimientos de asignación y revocación de permisos, especificando los roles y los permisos correspondientes.
- **Políticas de Seguridad:** Mantener un registro continuo de las políticas de seguridad, versiones y cambios, asegurando que cada empleado firme un registro de aceptación de las políticas.
- **Cifrado de Datos:** Registro de métodos de cifrado y configuración de seguridad aplicada para el almacenamiento y la transmisión de los datos.
- **Evaluación de Riesgos:** Guardar las evaluaciones de riesgos y plan de tratamiento en un registro centralizado, con notas sobre la implementación de controles adicionales.
- **Capacitación en Seguridad:** Llevar un registro de las sesiones de capacitación y resultados de las evaluaciones de concienciación para cada empleado.

2. Documentación del Monitoreo:

- Documentar los hallazgos de las auditorías, revisiones y evaluaciones de cumplimiento de cada control.
- Registrar las acciones correctivas tomadas ante cualquier fallo identificado.
- Mantener un historial de monitoreo para cada control que permita realizar comparaciones y evaluar la mejora continua en seguridad.

3. Alineación con ISO 27001:

- Asegurar que cada documento esté estructurado según los requisitos de **ISO 27001**, con el fin de facilitar auditorías internas y externas y también establecer un ciclo de revisión regular para cada documento, asegurando que se mantengan actualizados y alineados con las mejores prácticas.

Consideraciones Finales

Al completar esta tarea, he establecido una estrategia para implementar, monitorear y documentar los controles de seguridad en Global Data Inc., alineados con los estándares de ISO 27001. Esta estructura no solo fortalece la seguridad de la información sensible, sino que también promueve una cultura de seguridad entre los empleados y facilita la detección de amenazas y corrección de fallos.